

كيف تبني مركز عمليات أمن (SOC) بموارد محدودة

دليلك لاكتشاف التهديدات والاستجابة لها بسرعة - حتى لو لم يكن لديك مركز عمليات أمن على مدار ٢٤ ساعة طوال أيام الأسبوع

إعداد: جيمس كاردر
مسؤول الأمن الرئيسي في لوقريثم (LogRhythm CSO) ونائب الرئيس في معامل لوقريثم

الأشخاص

العمليات

التكنولوجيا



فهرس المحتوى

٣	مقدمة
٤	ما الذي يجعل مركز عمليات الأمن SOC أداة فعّالة؟ دمج الأشخاص والعمليات والتكنولوجيا
٥	الأشخاص
٧	لعمليات
٨	التكنولوجيا
١٠	تقدير حجم التكاليف والتوفير لمركز عمليات الأمن
١٢	مقارنة التكلفة لمختلف نماذج التوظيف في مركز عمليات الأمن
١٤	خطوات بناء مركز عمليات الأمن بـموارد محدودة
١٥	تطوير الإستراتيجية
١٥	تصميم الحل
١٦	إنشاء العمليات والإجراءات والتدريب
١٧	تجهيز البيئة
١٧	تنفيذ الحل
١٨	تشغيل حالات الاستخدام الشاملة
١٨	المحافظة والتطوير
١٩	الخاتمة
٢٠	نبذة عن لوقريثم
٢١	نبذة عن جيمس كاردن

كيف تبني مركز عمليات أمن (SOC) بموارد محدودة

مقدمة

- بعض المؤسسات يكون لديها مراكز عمليات أمنية رسمية وثابتة (SOCs). تعمل هذه المراكز الرسمية (SOCs) على مدار ٢٤ ساعة طوال أيام الأسبوع، وهي مناطق مُحكمة الأمان حيث يقوم فريق من المحللين المتخصصين بمراقبة التهديدات بعناية كبيرة.
- يقوم المحللون بالتحقق من ضوابط أمان بنية مؤسستهم لتحديد أي علامات محتملة للتسلل وإختراق البيانات، والتي قد تتطلب استجابة من قبل المستجيبين للحوادث بالمؤسسة.
- لسوء الحظ، لا تستطيع معظم المؤسسات تحمل تكلفة مركز عمليات أمن (SOC) على مدار ٧x٢٤. تكلفة وجود محللين مدربين تدريباً جيداً في جميع الأوقات داخل المؤسسة تفوق حجم الفوائد التي سيقدمونها، وهذا ينطبق على كل المؤسسات تقريباً. بدلاً من ذلك، فإن معظم المؤسسات إما تكتفي بمركز عمليات غير رسمي يتألف من عدد صغير من المحللين الذين لديهم العديد من المهام الأخرى التي يتعين عليهم القيام بها، أو ليس لديهم مركز عمليات (SOC) على الإطلاق ويعتمدون على استعارة أشخاص من أدوار أخرى عند الحاجة. في هذه الحالة فإنه لا يتم مراقبة الأحداث الأمنية باستمرار على مدار الساعة.
- يؤدي هذا إلى تأخيرات كبيرة في الاستجابة للعديد من الحوادث، بينما تمر حوادث أخرى دون أن يلاحظها أحد. إنه موقف خطير ينتج عنه حوادث إلكترونية ضارة. بالإضافة، فإنه من غير المحتمل أن يكون لدى المحللين
- أي وقت ليكونوا استباقيين للبحث عن التهديدات والهجمات مبكراً.
- وعندما يقع حدث ما، لا تستطيع العديد من المؤسسات الاستجابة بكفاءة وفعالية لأنها تفتقر إلى القدرات والعمليات اللازمة للاستجابة الرسمية للحوادث.
- بالنسبة لهذه المؤسسات العالقة بين التكلفة الباهظة لمركز الأمن الرسمي (SOC) والحماية غير الكافية على الإطلاق من مراكز الأمن الغير رسمية، هناك حل: بناء مركز عمليات (SOC) يقوم بأتمتة أكبر قدر ممكن من العمل. يمكن أن تساعد الأتمتة الفريق في إجراء مراقبة مستمرة للأحداث الأمنية وتحليلها لاكتشاف عمليات التسلل المحتملة. ويمكنه أيضاً توفير إمكانية أتمتة الاستجابة للحوادث والتنسيق لإدارة وتسريع معالجة الحوادث.
- الغرض من هذا المستند التمهيدي التعريفي هو توضيح كيفية إنشاء مركز عمليات SOC بنجاح، حتى مع الموارد المحدودة. تشرح الورقة أساسيات مراكز العمليات SOC، وتقدم تفاصيل حول ما تعنيه SOC من حيث الأشخاص والعمليات والتكنولوجيا.
- أخيراً، سنتعلم منهجية إنشاء مركز عمليات أمن SOC بموارد محدودة، مع التركيز على التكتيكات التي ستجعل طررك سلساً وناجحاً.
- بعد قراءة هذه الورقة، ستكون مؤسستك جاهزة لبدء التخطيط لمركز عمليات الأمن SOC الخاص بها.

ما الذي يجعل مركز عمليات الأمن SOC أداة فعّالة؟ دمج الأشخاص والعمليات والتكنولوجيا

من خلال أتمتة مركز عمليات الأمن SOC، ستتمكن من تحقيق فوائد مماثلة مع أنواع أخرى من الهجمات والتهديدات. ذلك سيُتيح لمؤسستك أن يكون لديها عدد صغير من المحللين الذين يركزون على المهام المعقدة والصعبة بدلاً من جحافل المحللين الذين يقضون معظم وقتهم في أداء المهام البسيطة والتي تستغرق وقتًا طويلًا لإتمامها. تعمل الأتمتة أيضًا على تحسين كفاءة عمليات مركز الأمن SOC بشكل كبير بحيث يتم اكتشاف الحوادث وإيقافها واستردادها بسرعة أكبر، وبالتالي تقليل الأضرار والتكاليف الأخرى.

لكي تُنشئ مركز عمليات أمن فعال، تحتاج إلى ثلاثة مكونات - الأشخاص والعمليات والتكنولوجيا - لبناء عملية أمنية ناجحة. سيقلل هذا من الاعتماد الكبير على الأشخاص ويحد من مركزية فريق الأمن SOC.

بالنسبة لمراكز الأمن SOC، فإن قوة الأتمتة بالغة الأهمية. فكر مثلاً في نوع الحادث الذي يحدث طوال الوقت: حملة الهجوم الإحتيالي (phishing). يمكن لمنصة عمليات أمن قوية أن تتعامل تلقائيًا مع كل جوانب عمليات الكشف والاستجابة والاستعادة، بما في ذلك:

- الكشف عن الحملة والتحقق من نطاقها والغرض منها.
- رصد خصائص الحملة ومقارنتها بالمكافحة الذكية للتهديد لتحسين فهم طبيعة التهديد.
- أتمتة عملية المعالجة بالكامل، بما في ذلك منع التهديد من استمرار شن الحملة، وحذف جميع رسائل البريد الإلكتروني الإحتيالية (phishing) من صندوق بريد المستخدم، وتحديد ما إذا كانت أي رسائل إحتيالية قد أدت إلى تنزيل و تثبيت أي حمولات ضارة، وعزل أي أنظمة مصابة، ومسح التعليمات البرمجية أو الشيفرات الضارة من الأنظمة.
- إعداد تقرير عن الحادث وتقديمه إلى الجهات المعنية.

الفقرات التالية ستشرح أكثر عن مركز عمليات الأمن SOC من حيث الأشخاص والعمليات والتكنولوجيا.



الأشخاص

بغض النظر عن مدى جودة أتمتة مركز عمليات الأمن SOC، فإن الأشخاص هم ضرورة مطلقة. أهم دورين في مركز عمليات الأمن هما المحلل الأمني والمستجيب للحوادث. بالنسبة لمحللي الأمن، فإن عملهم الأساسي في عمليات الأمن يكون في مراحل المراقبة والكشف عن التهديد. عادة ما تتضمن مهامهم مراقبة الإنذارات من نظام متعدد الإمكانيات وإجراء الفرز لتحديد الإنذارات التي تتطلب تدخل المستجيبين للحوادث. مهام المستجيب للحوادث قد تشمل ما يلي:

- إجراء تحليل أعمق للأحداث الأمنية المشبوهة باستخدام:
 - مصادر المكافحة الذكية للتهديد
 - تقنيات التحليل الجنائي الأساسية
 - أدوات تحليل البرامج الضارة
 - القيام بالاستجابة للحوادث كلما اقتضت الضرورة ذلك.
 - إبقاء الإدارة على علم بجهود الاستجابة للحوادث. هناك أدوار محتملة أخرى في مركز الأمن من ضمنها محلي التحليل الجنائي ومهندسي عكس البرامج الضارة.
- مهندس الأمن هو الدور الأخير المهم بدوام جزئي لأي مركز عمليات أمن SOC. عادةً ما يكون مهندس الأمن داخل مؤسسة الأمان ولديه فهم عميق لبرنامج أمان المؤسسة وبنيتها التحتية. يجب أن يساعد هذا الشخص في تصميم الحلول الأولية لمركز الأمن SOC والإشراف على تنفيذها لضمان كفاءته وفعاليته. بمرور الوقت ، يمكن لمهندس الأمان تخطيط وتنفيذ التعديلات على حلول عمليات الأمن SOC، بما في ذلك التوسعات اللازمة لتلبية الاحتياجات الإضافية للمؤسسة. يعد دور مهندس الأمان مهمًا بشكل خاص لأن قرارات المهندس ستؤثر بشكل كبير على برنامج الأمان وبالتالي تؤثر على المؤسسة بأكملها.
- لدى المنظمات العديد من الخيارات عندما يتعلق الأمر بكيفية تعيين موظفي مركز عمليات الأمن SOC. فيما يلي بعض الأمثلة لنماذج التوظيف المحتملة لمركز عمليات الأمن:

موظفين من داخل المؤسسة بالكامل

تشمل خيارات توظيف فريق الأمن SOC من داخل المؤسسة ما يلي:

- **فريق أمن ٧×٢٤:** الحصول على تغطية على مدار ٢٤ ساعة طوال أيام الأسبوع من قبل موظفي فريق الأمن SOC سوف يتطلب وجود العديد من محلي الأمن بدوام كامل (FTEs) والعديد من المستجيبين للحوادث بدوام كامل (FTEs). بالإضافة إلى ذلك، سيتولى الموظفون معظم الوظائف المتخصصة والاستعانة بمصادر خارجية يكون قليل جداً.
- **فريق أمن ٨×٥:** تقلل المؤسسات من المخاطر بشكل كبير من خلال استخدام منصة للمعلومات الأمنية وإدارة الأحداث (SIEM) كي تقوم بأتمتة وتسهيل القدرات الأمنية. باستخدام هذه الطريقة، يمكنك إنشاء تصعيد وإشعارات آلية لفريق المحللين لديك استناداً إلى مدى أهمية وتأثير أي تنبيه، كتعويض عن عدم توظيف عملية كاملة على مدار الساعة طوال أيام الأسبوع.

الاستعانة بمصادر خارجية بالكامل

في هذا النموذج، يتم ملء جميع وظائف مركز الأمن SOC بواسطة مزود خدمة أمان مُدار (MSSP) أو متعاقد خارجي آخر. يتصل المتعاقد الخارجي بالمؤسسة فقط عندما يُطلب منه المشاركة في جهود الاستجابة للحوادث أو الإجابة على سؤال حول تفاصيل بيئة المنظمة.

هجين (مزيج من الموظفين والاستعانة بمصادر خارجية)

غالبًا ما تتضمن النماذج الهجينة موظفين يغطون ساعات العمل الرئيسية فيما يتعامل المتعاقدون الخارجيون مع باقي الساعات. على سبيل المثال، في بيئة عمل مدتها ٨ × ٥، قد تحتاج المؤسسة إلى ما لا يقل عن اثنين من الموظفين بدوام كامل (FTEs) وهما: محلل أمني FTE ومستجيب للحوادث FTE. بالنسبة لجميع الأعمال التي تحدث خارج ساعات العمل أوالتي تتطلب أدوار أخرى بخلاف محلل الأمن والمستجيب للحوادث يتم حينها الاستعانة بمتعاقد خارجي.

نموذج هجين آخر هو زيادة أداء مركز الأمن الداخلي SOC عن طريق مزود خدمة الأمن المُدار MSSP والذي يعمل طوال ٧ × ٢٤ أو كما يسمى "عيون على الشاشة / eyes on glass". سيقوم مزود خدمات الأمن MSSP في هذا النموذج ببناء حالات استخدام مخصصة ومصممة خصيصاً للمؤسسة. يعتمد نجاح مثل هذا النموذج الهجين على أمداد مزود الأمن MSSP بأكبر قدر ممكن من المعلومات عن سياق الأعمال حتى يكون برنامج MSSP فعالاً في تلبية احتياجات المؤسسة وتوقعاتها.



العمليات

بغض النظر عن نموذج التوظيف الذي تستخدمه أي مؤسسة، فإن كل مركز عمليات أمن SOC يعتمد على العمليات. من المعروف أن التكنولوجيا تجمع الأشخاص والعمليات معًا، مثل منصة SIEM - متعددة الإمكانيات - التي تُعلم محلل الأمن في حال وجود شيء يحتاج إلى اهتمام فوري، أو عندما يقوم أحد المستجيبين للحوادث بإعطاء أمر لمنصة SIEM للقيام بشيء ما نيابة عنه. لكن العمليات تساعد الأشخاص أيضًا على العمل مع بعضهم البعض. على سبيل المثال، قد يقوم محلل أمني بوضع علامة على مجموعة من الأحداث في منصة SIEM لإخطار المستجيب للحوادث بضرورة التحقق منها أكثر. توفر منصة SIEM إمكانية تسيير العمل بشكل تنقل فيه مسؤولية بعض الأعمال من محلل الأمان إلى المستجيب للحوادث.

منصات SIEM المتكاملة يمكنها أن تعزز من إمكانية التواصل والتعاون وتسيير العمل والتنسيق بين أعضاء الفريق بشكل متطور أكثر في مراكز عمليات الأمن SOC. عند وقوع حادث أمني كبير، قد يساعد العديد من المحللين الأمنيين والمستجيبين للحوادث والمتخصصين في البحث الجنائي الرقمي جميعًا في حله، وقد يشارك أيضًا آخرون داخل المؤسسة مثل مسؤولي النظام والشبكات. من خلال دمج منصة SIEM ومركز عمليات الأمن SOC مع العمليات وطريقة سير العمل الجارية، فإن المؤسسة بذلك تقوم بتعزيز تبنيتها لمركز عمليات الأمن SOC وزيادة فرص نجاحه مع ضمان بذل جهود سريعة وفعالة في جميع أقسام المؤسسة لاكتشاف التهديدات والاستجابة لها. يؤدي هذا الإجراء إلى تجنب حدوث خطأ ترتكبه العديد من المؤسسات - وهو إجبار جميع العمليات والأعمال الجارية على التغيير لكي تتماشى مع مركز عمليات الأمن SOC.

في هذه الحالات، يعد الحصول على منصة SIEM المتكاملة أمرًا ضروريًا لأنها تؤدي أتمتة الأمان والتنسيق لضمان أن يكون الجميع على اطلاع دائم بالحالة الأمنية ولديهم إمكانية الوصول إلى جميع المعلومات اللازمة. يمكن للمنصة أيضًا أن تقوم بتزويد الأشخاص بالأدوات التي يحتاجون إليها للعمل معًا ولتوجيه المهام من شخص أو من فريق إلى آخر. أخيرًا، توفر منصة SIEM المتكاملة القدرة على التحقق من سير العمل لضمان عدم التغاضي عن أي شيء أو التعامل معه ببطء شديد.

التكنولوجيا



تُعد المنصة المتكاملة مثالية لبناء مركز عمليات الأمن (SOC) لأنها تقوم باحتواء ودمج جميع الصيغ اللازمة لأتمتة عمليات الأمان وتنسيق الاستجابة للحوادث في شاشة عرض واحدة.

فيما يلي بعض الأمثلة لما يمكن أن تقوم به منصة SIEM:

- التفاعل مع إدارة الأصول والممتلكات، وإدارة الثغرات الأمنية، برامج تسجيل ومتابعة الشكاوي، ومنع التسلل، والأنظمة الجارية الأخرى لدمج عمليات الأمن SOC تلقائيًا مع عمليات أعمال المؤسسة. هذا يُسرّع سير العمل بشكل كبير ويقلل من عبء العمل على الموظفين في العديد من الإدارات.
- تفعيل الاستجابات الآلية المرتبطة تلقائيًا بإنذارات معينة. بعض الإجراءات التي يمكن البدء بها دون تفاعل بشري أو التي تتطلب الموافقة بنقرة واحدة يمكن أن تفيد فريقك بشكل كبير في توفير الوقت للاستجابة لحادث ما. بمقدور منصة SIEM الشاملة التعرف على الحوادث الشائعة، مثل اختراق أولي من أحد البرامج الضارة، وتستطيع أن تستجيب تلقائيًا حتى يتمكن الفريق من التركيز على الأحداث والحوادث الأكثر تعقيدًا وتأثيرًا.

• ركزية جميع بيانات البحث الجنائي الرقمي مما يؤدي إلى دعم التحليلات الآلية الفعالة وتفعيل التحقيقات الأمنية السريعة، بحيث يمكن مراقبتها في جميع الأوقات ويمكن استخدام التحليلات لتحديد الأحداث ذات الأهمية الخاصة، وهذا يلغي الحاجة إلى وجود أشخاص يبحثون في بيانات الأحداث الأمنية الأولية على الشاشات طوال ٢٤ ساعة.

• توفير سياق للأحداث والحوادث الأمنية من خلال دمج مصادر معلومات استخبارات التهديد الخطيرة وبيانات نقاط الضعف، بالإضافة إلى المعلومات من الأنظمة المدمجة في الموارد البشرية والتمويل والتعاقد ، إلخ. فيما يتعلق بأنظمة الأعمال والأصول، يُمكن هذا السياق محلي الأمن من تحديد ما قد يحاول المهاجم فعله ولماذا.

• تحديد الأحداث المهمة بالأولوية، بناءً على المخاطر النسبية التي تتعرض لها المؤسسة بحيث يمكن لموظفي مركز عمليات الأمن الانتباه أولاً إلى الأحداث الأكثر أهمية.

• جمع الأدلة معًا في مكان واحد ومشاركتها بطريقة آمنة مع الأفراد المصرح لهم، مثل الموظفين عن بُعد والمتعاقدين الخارجيين المشاركين في جهود الاستجابة للحوادث.

• استخدام القدرة على متابعة سير العمل لتنبيه كل شخص/ دور عندما يحين دوره للقيام بشيء ما لمركز العمليات الأمن SOC، مثل مراجعة حادثة تم وضع علامة عليها على أنها عالية الخطورة.

كيف تقوم لوقريثم LogRhythm بتشغيل مركز عمليات الأمن SOC.

يجمع LogRhythm بين الحلول المتباينة تاريخيًا في منصة واحدة موحدة ، والتي نطلق عليها منصة لوقريثم نكست جين إس آي إي إم (the LogRhythm NextGen SIEM Platform). تقوم هذه المنصة بمنح مركز العمليات الأمنية SOC الخاص بك وجهة واحدة (شاشة واحدة) يمكن من خلالها تقييم الإنذارات والتحقيق في التهديدات والاستجابة للحوادث.

تعمل إمكانية التحليلات الأمنية الحاصلة على براءة اختراع من لوقريثم LogRhythm على أتمتة اكتشاف التهديدات الحقيقية وتحديدتها بأنها أولوية. بالإضافة إلى ذلك، توفر المنصة آليات لتنظيم وأتمتة عمل الاستجابة للحوادث. عندما تُفعل قدرات منصة SIEM بشكل كامل، جنبًا إلى جنب مع التشغيل الآلي القوي، فإن مركز عمليات الأمن SOC الخاص بك يمكن أن يعمل بكفاءة وفعالية أكبر لتحقيق وقت أسرع في المتوسط للكشف والاستجابة للتهديدات.

تتيح منصة لوقريثم نكست جين إس آي إي إم "LogRhythm NextGen SIEM Platform" للمؤسسات بناء مراكز عمليات أمن فعالة من حيث التكلفة وتقلل من المخاطر وتمنع انتهاكات البيانات الرئيسية وغيرها من الحلول. يؤدي هذا أيضًا إلى إعطاء المؤسسات فرصة أكبر للحصول على قيمة أفضل بكثير من موظفيها، والاستفادة منهم بشكل أكبر في المشاريع الإستراتيجية ذات الفوائد طويلة الأجل بدلاً من العمليات اليومية اليدوية.

لمزيد من المعلومات حول منصة لوقريثم نكست جين إس آي إي إم LogRhythm NextGen SIEM Platform ، قم بزيارة logrhythm.com/demo

يمكن لمنصة SIEM المستخدمة جنبًا إلى جنب مع نموذج توظيف مناسب لفريق مركز عمليات الأمن SOC بالإضافة إلى العمليات الأمنية الفعالة، يمكنها أن تحقق تكامل وتسيير للأعمال وتواصل سلس لجميع المهام المتعلقة بمركز الأمن SOC، بغض النظر عن الاستعانة بمتعاقد خارجي. هذه التركيبة تتيح أيضًا الوصول الفوري إلى المعلومات والبيانات والأحداث وسجلات التحقيق التي يحتاجها الموظفون داخل المؤسسة والمتعاقدون الخارجيون المصرح لهم، في أي وقت ومن أي مكان.



تقدير حجم التكاليف والتوفير لمركز عمليات الأمن

متشابهة إلى حد ما عبر النماذج التوظيف في مراكز الأمن SOC على اختلاف أحجامها لأن معظم البنية التحتية نفسها يجب أن تكون مجهزة سواء كان لديك فريق موظفين ٨ × ٥ أو ٢٤ × ٧ في الموقع. الاستثناء الوحيد يكون في نموذج مركز الأمن SOC الذي يتم الاستعانة فيه بمتعاقدين خارجيين بالكامل، لأنه لا يتطلب مرافق أو معدات أو أنظمة لموظفي مركز عمليات الأمن.

الاعتبارات النهائية لتكاليف مركز عمليات الأمن SOC يجب أن تشمل مدى فعالية المركز في منع الحوادث واكتشاف الحوادث ووقفها بسرعة واستعادة العمليات الطبيعية.

عملية تحويل مركز عمليات الأمن من قسم غير رسمي إلى مركز أمن جيد التنظيم باستخدام منصة SIEM يمكن أن تقلل التكاليف بقيمة ملايين الدولارات سنوياً والتي قد تُصرف لمعالجة الحوادث وفقدان إنتاجية المستخدم وخسارة الأعمال بسبب الحوادث التي تمنع المؤسسة من إجراء عملياتها بطريقة طبيعية.

فكر مثلاً في حادثة برامج ضارة بسيطة في مؤسسة تضم ٥٠٠٠ مستخدم. مركز عمليات الأمن غير الرسمي التابع للمؤسسة لا يعمل على مدار الساعة، لذلك لا يتم اكتشاف حادثة البرامج الضارة حتى يتأثر حوالي ١٠٠ نظام. يجب بعد ذلك إعادة بناء كل نظام من هذه الأنظمة، حيث تستغرق كل عملية إعادة بناء واستعادة وإعادة نشر في المتوسط أربع ساعات من وقت مسؤول النظام. بالإضافة، فإن مستخدمي هذه الأنظمة المائة لن يستطيعوا القيام بمعظم عملهم خلال هذا الوقت. إذا افترضت خسارة كلية للإنتاجية تصل إلى ٥٠٠ ساعة بالإضافة إلى ٤٠ ساعة من وقت مسؤول النظام لكي يعيد بناء النظام، فإن حادث البرامج الضارة هذا يكلف

يعتمد مقدار تكلفة مركز الأمن SOC على العديد من العوامل، كما هو الحال مع حجم التوفير الذي يمكن أن يقدمه مركز عمليات الأمن للمؤسسة. دعنا نبدأ بالنظر في التكاليف السنوية للعمالة والخدمات المقدرة لنماذج التوظيف العامة لمراكز الأمن الصغيرة والمتوسطة والكبيرة (SOC). (انظر مقارنات التكلفة لمختلف نماذج التوظيف في مراكز الأمن في الصفحة ١٢). تُظهر هذه التقديرات أنه بالنسبة لجميع أحجام مراكز عمليات الأمن، فإن تكاليف العمالة والخدمة هي الأعلى بالنسبة لشركات العمليات الأمنية التي لا تعتمد على نظام أساسي أو منصة للمعلومات الأمنية وإدارة الأحداث (SIEM). ويرجع ذلك إلى وجود المزيد من عمليات المراقبة والتحليل والتحقيق وتحديد الأولويات وجمع بيانات الأدلة الجنائية والاستجابة للحوادث والإدارة وإعداد التقارير التي يتعين على الأشخاص القيام بها بدلاً من منصة SIEM.

النوع الرئيسي الثاني من تكاليف مراكز العمليات (SOC) هو البنية التحتية، بما في ذلك المرافق والمعدات والشبكات والأنظمة والبرمجيات ورسوم الاشتراك (على سبيل المثال، موجز معلومات استخبارات التهديدات).

على أي حال فإنه من الصعب تعميم هذه التكاليف. على سبيل المثال، قد يكون لدى إحدى المؤسسات مساحة منشأة غير مستخدمة متاحة للاستخدام الفوري لمركز عمليات الأمن، بينما قد تحتاج مؤسسة أخرى إلى الحصول على مساحة جديدة وإعدادها. قد يكون لدى إحدى المؤسسات شبكات وأنظمة متاحة بسهولة لمركز الأمن SOC، بينما قد تحتاج أخرى إلى تصميمها وشراؤها وتنفيذها.

ومع ذلك، بشكل عام فإن تكاليف البنية التحتية

٩٠٠ ساعة عمل. إذا قدرنا تكلفة الساعة الواحدة بـ ١٠٠ دولار تقريبًا، هذا ما يقرب من ١٠٠,٠٠٠ دولار خسائر في يوم واحد. المراقبة المتواصلة على مدار الساعة من منصة SIEM و برنامج خدمة الأمن المُدار MSSP يمكنها اكتشاف وإيقاف حادثة مثل هذه في وقت مبكر جدًا، مما يمنع جميع هذه الأنظمة تقريبًا من التأثر ويوفر ما يقرب من ١٠٠,٠٠٠ دولار من التكاليف. هذا أكثر مما ستكلفه خدمات الأمن المُدار MSSP لمدة ثلاثة أشهر.

من خلال تحويل مركز عمليات الأمن SOC إلى نموذج يشتمل على منصة SIEM شاملة، يمكن أن تحقق توفيراً كبيراً في التكاليف المستمرة لمؤسستك.



ملاحظة من خبير :

المراقبة المتواصلة على مدار الساعة من منصة SIEM و برنامج خدمة الأمن المُدار MSSP يمكنها اكتشاف وإيقاف حادثة البرامج الضارة في وقت مبكر جدًا، مما يمنع جميع هذه الأنظمة تقريبًا من التأثر ويوفر ما يقرب من ١٠٠,٠٠٠ دولار من التكاليف. هذا أكثر مما ستكلفه خدمات الأمن المُدار MSSP لمدة ثلاثة أشهر.

مقارنة التكلفة لمختلف نماذج التوظيف في مركز عمليات الأمن SOC

مركز أمن كبير مستخدم أكثر ٥٠,٠٠٠	مركز أمن متوسط ١٠,٠٠٠-٥٠,٠٠٠	مركز أمن صغير مستخدم أقل ١٠,٠٠٠	
مركز أمن SOC بدون منصة SIEM	٨x٥ فريق متواجد بالموقع	٢x٤ فريق متواجد بالموقع	٢x٤ فريق متواجد بالموقع
محلي الأمن	٢ بدوام كامل @ ١٢٠ ألف \$ لكل منهما	٨ بدوام كامل @ ١٢٠ ألف \$ لكل منهم	٢٠ بدوام كامل @ ١٢٠ ألف \$ لكل منهم
المستجيبون للحوادث	١ بدوام كامل @ ١٤٥ ألف \$ لكل منهما	٤ بدوام كامل @ ١٤٥ ألف \$ لكل منهم	٨ بدوام كامل @ ١٤٥ ألف \$ لكل منهم
المتخصصون (مهندسي عكس البرامج الضارة، ومحلي البحث الجنائي الرقمي، وما إلى ذلك)	٠ دوام كامل: الاستعانة بمصادر خارجية والدفع عند الحاجة (٥٠ ألف دولار في السنة تقريبا)	٢ بدوام كامل @ ١٥٠ ألف \$ لكل منهم	٥ بدوام كامل @ ١٥٠ ألف \$ لكل منهم
الإدارة	١ بدوام كامل @ ١٤٥ ألف \$	٢ بدوام كامل @ ١٤٥ ألف \$	٣ بدوام كامل @ ١٤٥ ألف \$
الإجمالي	٥٨٥ ألف \$	٢,١٤٠ ألف \$	٤,٧٦٠ ألف \$
مركز أمن من داخل المؤسسة بالكامل يعمل بمنصة SIEM	٨x٥ فريق متواجد بالموقع	١٦x٥ فريق متواجد بالموقع	٢٤x٧ فريق متواجد بالموقع
محلي الأمن	١ بدوام كامل @ ١٢٠ ألف \$	٤ بدوام كامل @ ١٢٠ ألف \$	٨ بدوام كامل @ ١٢٠ ألف \$
المستجيبون للحوادث	١ بدوام كامل @ ١٤٥ ألف \$	٢ بدوام كامل @ ١٤٥ ألف \$	٤ بدوام كامل @ ١٤٥ ألف \$
المتخصصون (مهندسي عكس البرامج الضارة، ومحلي البحث الجنائي الرقمي، وما إلى ذلك)	٠ دوام كامل: الاستعانة بمصادر خارجية والدفع عند الحاجة (٢٥ ألف دولار في السنة تقريبا)	١ بدوام كامل @ ١٥٠ ألف \$	٢ بدوام كامل @ ١٥٠ ألف \$
الإدارة	٢٥ بدوام كامل @ ١٥٠ ألف \$	٥ بدوام كامل @ ١٥٠ ألف \$	١ بدوام كامل @ ١٥٠ ألف \$
الإجمالي	٣٣٨ ألف \$	٩٩٥ ألف \$	١,٩٩٠ ألف \$

مركز أمن كبير مستخدم ٥٠,٠٠٠ أكثر	مركز أمن متوسط ١٠,٠٠٠-٥٠,٠٠٠	مركز أمن صغير مستخدم ١٠,٠٠٠ أقل	
مركز أمن هجين يعمل بمنصة SIEM	٨ × ٥ في الموقع، جميع الأوقات الأخرى خارج الموقع ٢٤ × ٧ MSSP	٨ × ٥ في الموقع، جميع الأوقات الأخرى خارج الموقع ٢٤ × ٧ MSSP	٢٤ × ٧ في الموقع
محلي الأمن	٠	٠	٠
المستجيبون للحوادث	٠	٠	٠
المتخصصون (مهندسي عكس البرامج الضارة، ومحلي البحث الجنائي الرقمي، وما إلى ذلك)	٠	٠	٠
الإدارة	٠	٠	٠
خدمات MSSP	٠	٠	٠
الإجمالي	٠	٠	٠
مركز أمن من خارج المؤسسة بالكامل يعمل بمنصة SIEM	٨ × ٥ في الموقع، جميع الأوقات الأخرى خارج الموقع ٢٤ × ٧ MSSP	٨ × ٥ في الموقع، جميع الأوقات الأخرى خارج الموقع ٢٤ × ٧ MSSP	٨ × ٥ في الموقع، جميع الأوقات الأخرى خارج الموقع ٢٤ × ٧ MSSP
محلي الأمن	٠	٠	٠
المستجيبون للحوادث	٠	٠	٠
المتخصصون (مهندسي عكس البرامج الضارة، ومحلي البحث الجنائي الرقمي، وما إلى ذلك)	٠	٠	٠
الإدارة	٠	٠	٠
خدمات MSSP	٠	٠	٠
الإجمالي	٠	٠	٠

خطوات بناء مركز عمليات الأمن بموارد محدودة

استنادًا إلى الخبرات التي تساعد مجموعة واسعة من المؤسسات، طور خبراء لوقريثم LogRhythm منهجية لبناء مركز عمليات الأمن SOC تستخدم منصة SIEM كاملة. البنود السبعة التالية تشرح كل خطوة من خطوات هذه المنهجية.



الخطوة ١: تطوير الإستراتيجية



فيما يلي جزآن مهمان جداً في تطوير إستراتيجية لمركز عمليات الأمن SOC :

١. تقييم القدرات الحالية لمركز الأمن SOC في المؤسسة من حيث الأفراد والعمليات والتكنولوجيا. عند إنشاء مركز عمليات الأمن ، يجب أن يقتصر النطاق الأولي للمركز SOC على الوظائف الأساسية: المراقبة والكشف والاستجابة والاستعادة. بعض مراكز عمليات الأمن تقوم بدعم وظائف إضافية، مثل إدارة الثغرات الأمنية، ولكن يجب تأجيل هذه الوظائف غير الأساسية حتى تنمو الوظائف الأساسية بشكل كافٍ.
٢. تحديد أهداف العمل لمركز عمليات الأمن. لكي يكون فعالاً، يجب أن تركز أهداف المركز على مساعدة المؤسسة على تحقيق أهداف أعمالها. إن إنشاء مركز عمليات SOC من أجل الأمن دون الأخذ في الاعتبار العوامل المؤثرة في العمل، مثل الأنظمة والبيانات الأكثر أهمية لاستدامة العمليات، سيؤدي حتماً إلى مشاكل في إظهار القيمة للأعمال، وقد يؤدي إلى عدم رصد تهديدًا رئيسيًا من قبل مركز عمليات الأمن مما ينتج عنه حادثة إلكترونية ضارة.

الخطوة ٢: تصميم الحل



بالتوافق مع النصيحة الواردة في الخطوة ١ بشأن تقييد النطاق الأولي لمركز الأمن SOC، قد يكون من الأفضل السعي في تحقيق بعض المكاسب السريعة بدلاً من إنشاء مركز أمن SOC واسع النطاق وواسع الوظائف. اختر عددًا قليلاً من حالات الاستخدام المهمة للأعمال وحدد الحل المبدئي استناداً إلى حالات الاستخدام هذه، مع الأخذ في الاعتبار أن الحل يجب أن يتوسع في المستقبل لتلبية الاحتياجات الإضافية. يساعد وجود حل مبدئي ضيق النطاق أيضاً على تقليل مقدار الوقت اللازم لتنفيذه وتحقيق النتائج الأولية بسرعة أكبر. عند تصميم حل لمركز الأمن SOC يجب أن تتضمن الإجراءات المهمة ما يلي:

١. تحديد المتطلبات الوظيفية. يجب ربط هذه المتطلبات بأهداف العمل كلما أمكن ذلك. تشمل مجالات المتطلبات الوظيفية ما يلي:
 - i. تحديد مصادر بيانات السجل والأحداث المراد مراقبتها
 - ii. تحديد مصادر معلومات استخبارات التهديد التي سيتم استخدامها
 - iii. تحديد متطلبات الأداء، مثل أوقات الاستجابة

٢. اختر نموذج لمركز الأمن SOC. يجب أن يستند هذا إلى المتطلبات الوظيفية التي تم تحديدها، بالإضافة إلى الاستراتيجية المحددة في الخطوة الأولى. تشمل القرارات التي يجب اتخاذها في هذه المرحلة تحديد الساعات والأيام للموظفين مقابل تلك للمتعاقدين الخارجيين، وكذلك تحديد مسؤوليات الموظفين ومسؤوليات من يتم الاستعانة بهم من متعاقد خارجي، والأدوار التي سيقوم بها مركز الأمن SOC، وعدد الموظفين بدوام كامل لكل دور.

٣. تصميم الهيكل التقني. هذا يشمل:

- i. تخطيط تركيب وترتيب مكونات الحل، وأبرزها منصة SIEM
- ii. تحديد نظام الأعمال وأنظمة المعلومات التي يجب دمجها مع منصة SIEM لتوفير سياق عمل للأحداث والحوادث الأمنية
- iii. تحديد سير العمل للأحداث والحوادث لتتماشى مع العمليات الحالية للمؤسسة
- iv. التخطيط لأتمتة الحل قدر الإمكان، بما في ذلك أتمتة التقنيات اللازمة للحصول على رؤية كاملة لمشهد التهديد الذي يهدد الأنظمة والبيانات، في النطاق الأولي لعمليات الأمن وإحباط الهجمات في وقت مبكر من الهجوم قدر المستطاع
- v. تحديد ما إذا كانت البنية التقنية سليمة، مثل إجراء تمارين تدريبية لجميع حالات الاستخدام لتحديد المشكلات المحتملة

الخطوة ٣: إنشاء العمليات والإجراءات والتدريب

إذا تم الاستعانة بمتعاقد خارجي لتغطية جزء من وظائف مركز العمليات الأمنية ، فمن المهم العمل مع المتعاقد لضمان أن العمليات والإجراءات والتدريب تتم بتناسق على كلا الجانبين.

الخطوة ٤: تجهيز البيئة



قبل اعتماد حل لمركز الأمن SOC، من الأهمية بمكان التأكد من أن جميع العناصر موجودة لتوفير بيئة آمنة لهذا الحل. تشمل العناصر البارزة تأمين أجهزة الكمبيوتر المكتبية والمحمولة والأجهزة المحمولة الخاصة بموظفي مركز عمليات الأمن؛ وجود آليات آمنة للوصول عن بُعد للموظفين (والمتقاعدين الخارجيين إن أمكن) للتفاعل مع حل مركز الأمن SOC، كما يجب أيضا وضع طريقة قوية وأمنة للتأكد من الهوية عند استخدام الوصول عن بعد لحل مركز الأمن (ويفضل أن يكون ذلك للوصول المحلي أيضًا)

الخطوة ٥: تنفيذ الحل



الطريقة المثالية لتنفيذ الحل نفسه هي التركيز على الاستفادة الكاملة من التكنولوجيا لتقليل عبء العمل على الأشخاص. هذا الحل هو عملية من أسفل إلى أعلى تبدأ من خلال:

- تنشئة البنية التحتية لإدارة السجل
- إعداد الحد الأدنى من جمع مصادر البيانات الهامة
- عرض إمكانات تحليلات الأمن
- إعداد قدرات الأتمتة الأمنية والتنسيق
- البدء في تفعيل حالات الاستخدام التي تركز على اكتشاف التهديدات الشاملة وتحقيق الاستجابة

عنصر أساسي آخر هو تحقيق التشغيل التبادلي السلس مع الأنظمة الأخرى، وذلك لجمع البيانات من المصادر وإصدار الإجراءات والأوامر للمساعدة في تطبيق السياق والاحتواء والمعالجة بما يتماشى مع مهام سير العمل. هذا الإجراء مفيد بشكل خاص لتقليل الوقت المستغرق للكشف عن الحوادث والاستجابة لها. يجب أن يشتمل الحل أيضًا على موجزات لأخبار معلومات التهديدات ومصادر استخبارات أخرى كمدخلات آلية لتحسين دقة الكشف.

الخطوة ٦: تشغيل حالات الاستخدام الشاملة

بمجرد تفعيل إمكانات الحل، يمكنك تنفيذ حالات الاستخدام عبر طبقة التحليلات والأتمتة الأمنية وطبقة التنسيق، مثل اكتشاف بيانات الاعتماد المخترقة وحملات التصيد الاحتيالي الناجحة. يجب عليك فحص ذلك خلال مجموعة متنوعة من المناوبات وكذلك أثناء تغيير المناوبات. جميع أشكال أتمتة الحلول المذكورة سابقاً من الضروري اختبارها بدقة كبيرة. يجب أيضاً التحقق من موثوقية وأمان الوصول إلى الحل عن بُعد إلى أقصى حد ممكن.

الخطوة ٧: المحافظة والتطوير

بمجرد أن يصبح الحل قيد التطبيق بالكامل، سيحتاج إلى صيانة مستمرة، مثل تحديث إعدادات التكوين والضبط بمرور الوقت لتحسين دقة الكشف، وإضافة أنظمة أخرى كمدخلات أو مخرجات للحل. ستحتاج إلى تضمين أعمال صيانة أخرى بشكل دوري، بما في ذلك مراجعة نموذج مركز عمليات الأمن SOC، وأدوار عمليات الأمن SOC، وعدد ساعات التوظيف بدوام كامل FTE وما إلى ذلك، لإجراء التعديلات اللازمة.

ملاحظة من خبير:

الطريقة المثالية لتنفيذ الحل نفسه هي التركيز على الاستفادة الكاملة من التكنولوجيا لتقليل عبء العمل على الأشخاص.



الخاتمة

- توفير إمكانية سير عمل متطورة للغاية وتنقل مسؤولية مهام محددة من شخص لآخر أو لدور آخر كلما دعت الحاجة. تحافظ هذه الخاصية على سير العمل بطريقة جيدة وتقلل من سوء الاتصالات الذي قد يؤخر عن غير قصد الإجراء أو يتسبب في مضاعفة الجهود.
- العمل على أتمتة تنسيق الاستجابة للحوادث بحيث يتمكن جميع الأشخاص المشاركين في الاستجابة للحوادث من الوصول الفوري إلى المعلومات الضرورية.

أصبح وجود مركز عمليات أمنية ضرورية مطلقة لتنفيذ نظام SIEM متعدد الإمكانيات لتقليل الضرر الناجم عن الهجمات الناجحة. يعتبر نموذج التوظيف الهجين لمراكز العمليات SOC هو الحل المناسب تمامًا للمؤسسات التي لا تستطيع رصد النفقات الباهظة لمراكز الأمن SOC الرسمية وفي نفس الوقت لا يمكنها تحمل الحماية غير الكافية التي توفرها مراكز الأمن SOC غير الرسمية.

منصة لوقريثم نكست جين إس آي إي إم LogRhythm NextGen SIEM هي التقنية المثالية لبناء مركز عمليات SOC. يمكن للمؤسسات التي تتبنى هذه الإستراتيجية تحقيق توفيرات فورية ومستمرة في التكاليف مقارنة بتبني أي نموذج آخر لـ مركز الأمن SOC. تؤدي هذه الإستراتيجية أيضًا إلى تقليل مادي في المخاطر التي تتعرض لها المؤسسة.

تشمل الطرق المحددة التي تستفيد المؤسسات من خلالها من منصة لوقريثم LogRhythm ما يلي:

- استخدام إمكانيات متقدمة لاكتشاف التهديدات وتحليلها، مثل تحليلات سلوك المستخدم والكيان والتي يمكنها اكتشاف وفهم أهمية العديد من أنواع التهديدات التي لا يمكن اكتشافها بسهولة بوسائل أخرى. هذا مفيد بشكل خاص لتحديد التهديدات الداخلية التي تحاول الوصول إلى البيانات الحساسة وسرقتها.

لمعرفة كيف يمكنك إنشاء مركز أمن SOC خاص بك باستخدام لوقريثم LogRhythm ، قم باختيار موعد عرض توضيحي مخصص لك:
logrhythm.com/schedule-online-demo



نبذة عن لوقريثم LogRhythm

لها وإبطالها بسرعة. تم تصميم لوقريثم LogRhythm بواسطة متخصصين في مجال الأمن ومن أجل متخصصين في الأمن، وهو يتيح لمخصصي الأمن في المؤسسات الرائدة مثل كارغيل Cargill و ناسا NASA وإيكسيل اينيرجي XcelEnergy تعزيز رؤيتهم لبرنامج الأمن السيبراني الخاص بهم وتقليل المخاطر التي تتعرض لها مؤسساتهم كل يوم. لوقريثم LogRhythm هو المزود الوحيد الذي فاز بخيار العملاء من Insights Peer Gartner لتعيين منصة SIEM لمدة ثلاث سنوات متتالية. لمعرفة المزيد، يرجى زيارة logrhythm.com

يمكن لوقريثم LogRhythm أكثر من ٤٠٠٠ عميل في جميع أنحاء العالم من تطوير برنامج عمليات الأمن الخاص بهم بشكل ملحوظ.

تقوم منصة نيكست-جن إس آي إي إم SIEM_ NextGen _ من مجموعة لوقريثم LogRhythm_ والتي حازت على عدد من الجوائز، بتوفير تحليلات أمنية شاملة؛ وتحليلات سلوك المستخدم والكيان (UEBA)؛ والتحري عن الشبكة والاستجابة لها (NDR)؛ وتنسيق الأمن والأتمتة والاستجابة (SOAR) ضمن منصة واحدة متكاملة أكتشاف التهديدات والاستجابة

نبذة عن جيمس كاردر



يتمتع جيمس كاردر بأكثر من ٢٠ عامًا من الخبرة في العمل في مجال أمن تكنولوجيا المعلومات للشركات والاستشارات لصالح فورتشن ٥٠٠ (Fortune ٥٠٠) والحكومة الأمريكية. بصفته مسؤول رئيسي لأمن المعلومات CISO ونائب رئيس معمل لوقريثم LogRhythm Labs ، فهو يقوم بتطوير والمحافظة على نموذج حوكمة الأمان للشركة واستراتيجيات المخاطر وحماية السرية والنزاهة وتوافر أصول المعلومات، ويشرف على إدارة التهديدات ونقاط الضعف، ويشرف كذلك على مركز العمليات الأمنية (SOC). كما أنه يدير المهمة والرؤية الإستراتيجية لإستخبارات البيانات الآلية في معمل لوقريثم LogRhythm Labs ، والتكاملات الاستراتيجية والتهديدات وفرق البحث الخاصة بالحوكمة. قبل انضمامه إلى لوقريثم LogRhythm ، شغل جيمس كاردر منصب مدير المعلوماتية الأمنية في Mayo Clinic ، حيث أشرف على استخبارات التهديدات والاستجابة للحوادث والعمليات الأمنية ومجموعات الأمن الهجومي. وقبل ذلك، عمل السيد كاردر كمدير أول في مانديانت Mandiant ، حيث قاد الخدمات المهنية وعمليات الاستجابة للحوادث. قاد التحقيقات الجنائية والمتعلقة بالأمن القومي على مستوى المدينة والولاية والمستوى الفيدرالي، بما في ذلك تلك المتعلقة بالتهديدات المستمرة المتقدمة (APT) وسرقة معلومات بطاقة الائتمان.

جيمس هو متحدث في فعاليات الأمن السيبراني وهو مؤلف مشهور للعديد من منشورات الأمن السيبراني، وهو حاصل على درجة البكالوريوس في العلوم في نظم المعلومات الحاسوبية من جامعة والدن، وماجستير إدارة الأعمال من كلية كارلسون للإدارة بجامعة مينيسوتا، وهو محترف معتمد في أمن نظم المعلومات (CISSP).



Office G02, Dubai Islamic Bank Building. Dubai Internet City, Dubai 33368, United Arab Emirates

PHONE: +97155 642 2224 EMAIL: metainfo@logrhythm.com